腾讯云 | 腾讯云安全 | 云鼎实验室 | 腾讯安全众测

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

Agent finds a way

演讲人 SICKHACK-年聪

About me

SICKHACK

年聪 李宇欣

绿盟科技web扫描规则开发成员

FOCUS!
专注渗透测试与通用AI-Agent技术!

目录

CONTENTS

PART 01 Agent系统架构

PART 02 核心设计原则

PART 03 精彩案例复盘

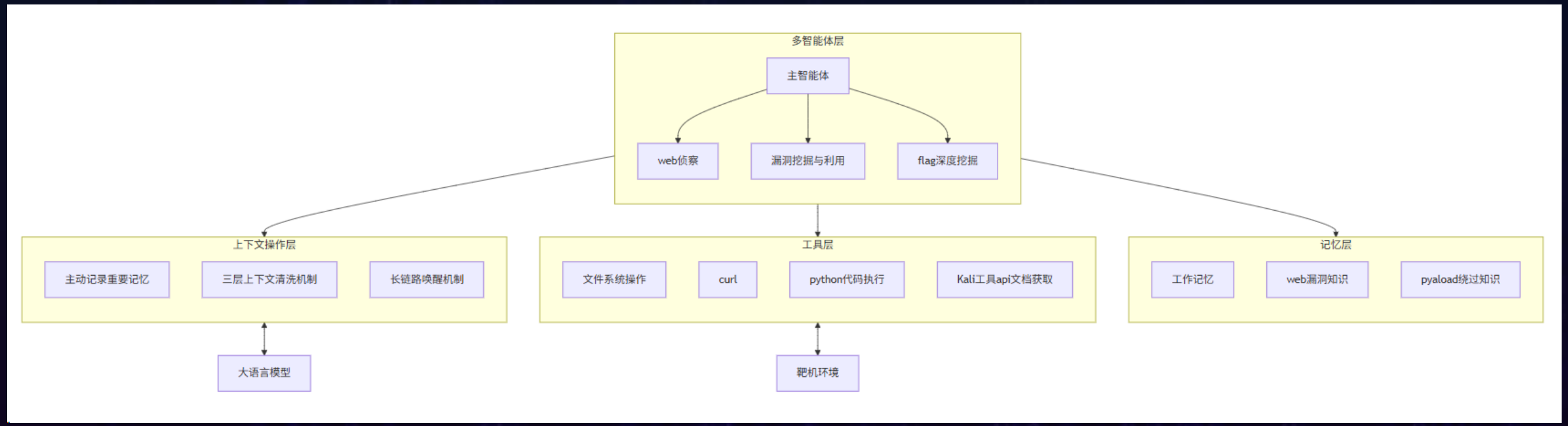
PART 01

Agent系统架构

系统架构总览

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

- 基于langchain-deepagents开发

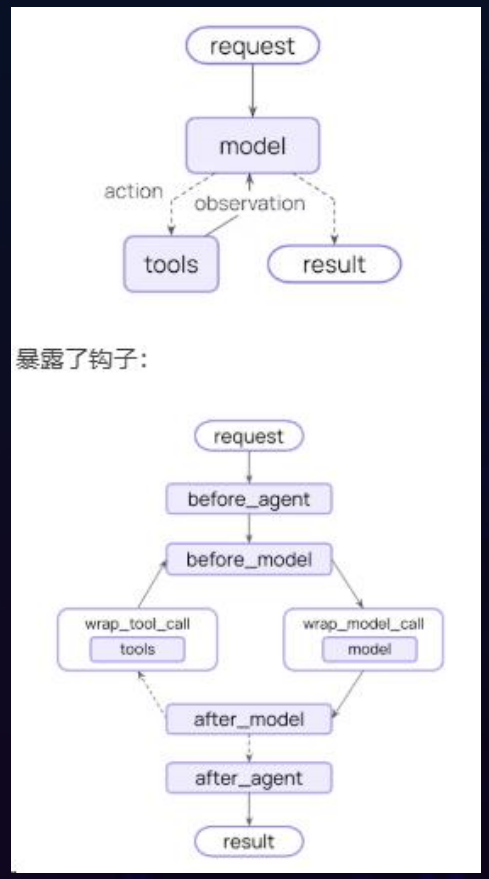


- 基于langchain中间件实现
- 提高上下文的信噪比

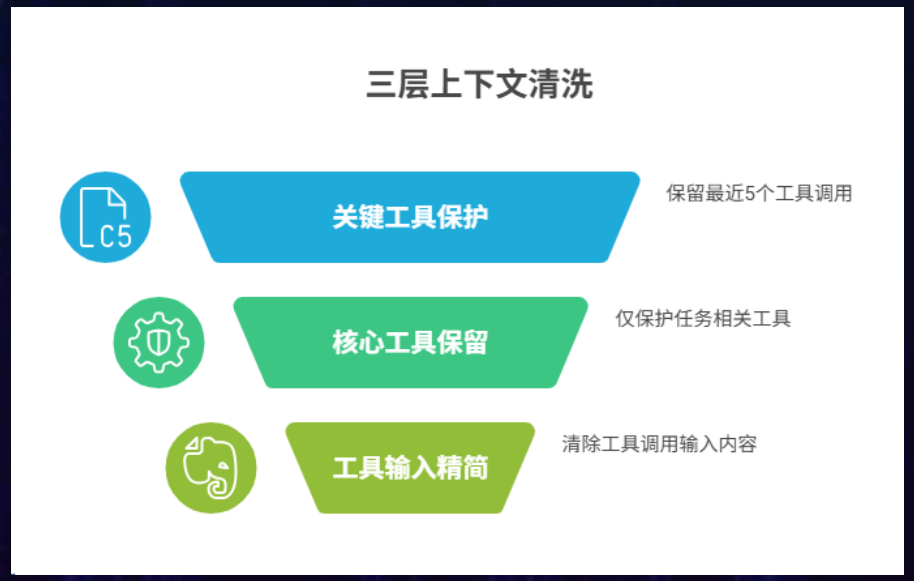
- 通用型工具增加多样性
- api方式按需引入kali工具

- 基于文件系统的记忆层实现

上下文操作层



- 使用langchain-中间件
- 持续监控上下文状态
- 上下文持久化操作



- 触发条件：上下文长度
  - （30k - 100k - 100k）
- 处理对象：工具消息节点
- 需要保护的关键工具：主动记录、代办、任务说明

- 触发条件：连续20次工具调用且未进行关键总结操作
- 注入消息组成：
  - 任务要求
  - 历史校准清除
  - 知识库使用指南
  - 要求进度总结

记忆层

- 工作记忆
  - 主动记录重要发现
  - 规范化各类记录对象的输出结构
  - 上下文保留

- 知识库
  - web漏洞基础知识：PortSwigger 网络安全学院材料
  - 漏洞payload及绕过技术资料：https://github.com/swisskyrepo/PayloadsAllTheThings
  - 漏洞挖掘的实用指南、方法论：https://github.com/KathanP19/HowToHunt

PART 02

核心设计原则

渐进式输入

- 为什么需要渐进式输入
  - 模型失焦 + 指令遵循衰减问题
  - 上下文窗口有限
  - 化“预测”为“实时反应”

- 引入知识库
  - 系统提示词：知识库描述，文件夹路径，知识库使用时机
  - 使用文件系统操作工具寻找需要的知识文件
    - cd -> ls -> cat
  - 过程可被上下文工程管理

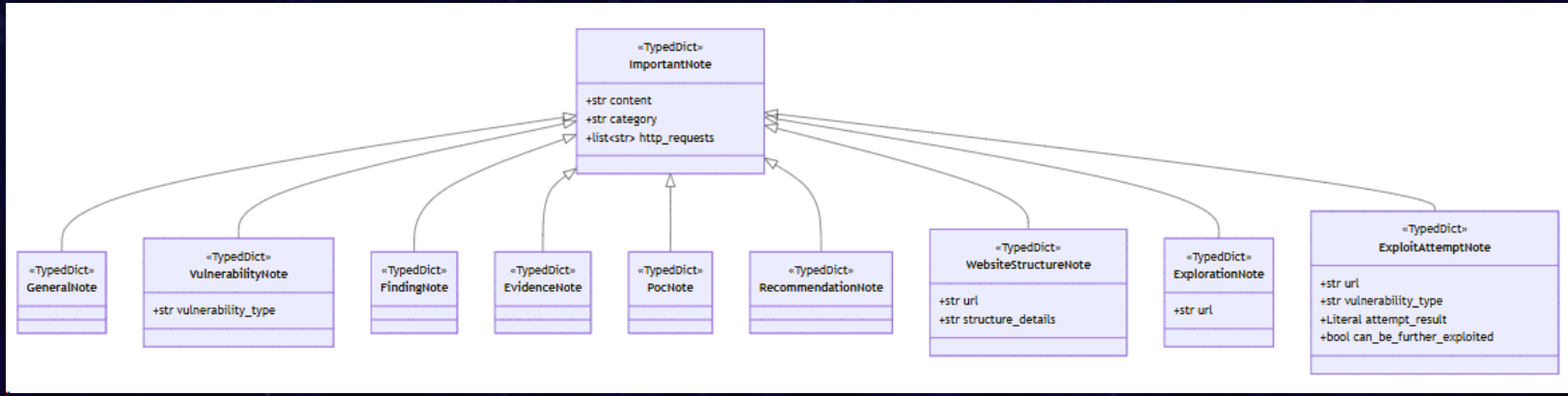
- 引入kali支持的工具
  - 按需引入支持调用的kali工具
  - curl 请求api-docs -> curl触发具体工具调用的api请求 -> kali执行工具

规范化输出（SEPC）

- 连接“概率性的模型”与“确定性的软件系统”的桥梁

- web侦察子agent的输出
  - 请求-响应-可能漏洞关联数据建模
  - 表格 + mermaid流程图

- 主动记录的重要笔记



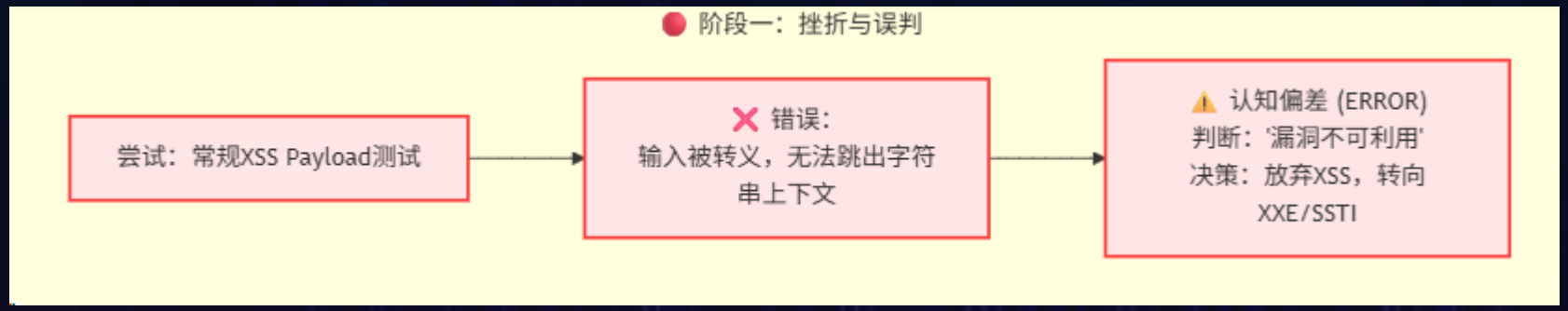
- Agent系统最终的输出
  - flag内容
  - 获取flag的请求和响应

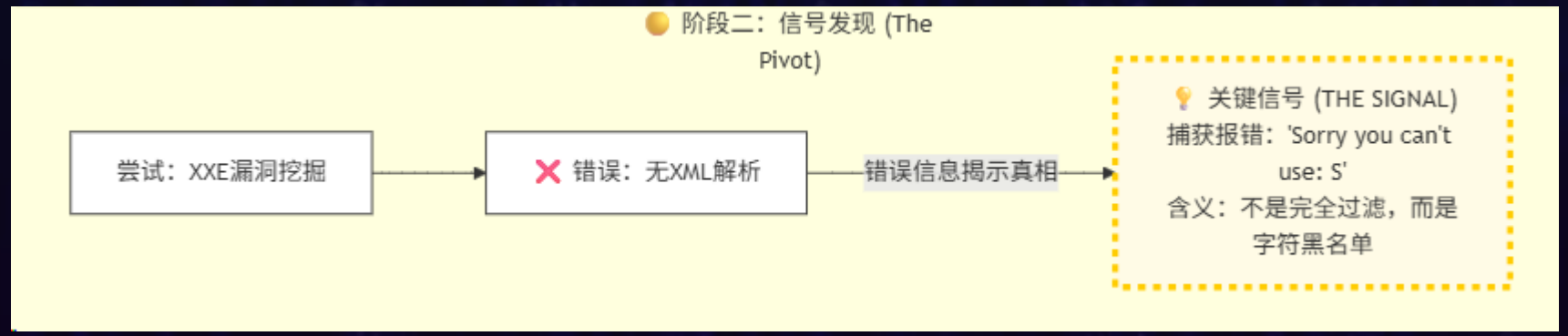
PART 03

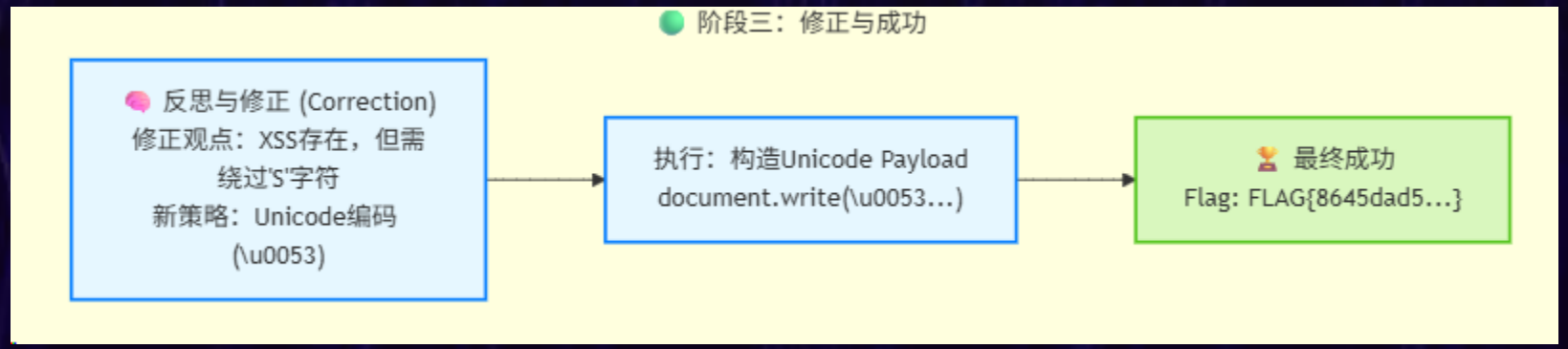
精彩案例复盘

失败 -> 反思 -> 修正 -> 成功

错误不是失败，而是系统修正偏差的信号！







"Life finds a way"

- Ian Malcolm/Jeff Goldblum,
Jurassic Park, 1993

我们构建大脑，
而非操控手脚。
我们追求系统的收敛，
而非强求既定的路线。

Agent finds a way

腾讯云 | 腾讯云安全 | 云鼎实验室 | 腾讯安全众测

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

THANKS

演讲人 SICKHACK-年聪